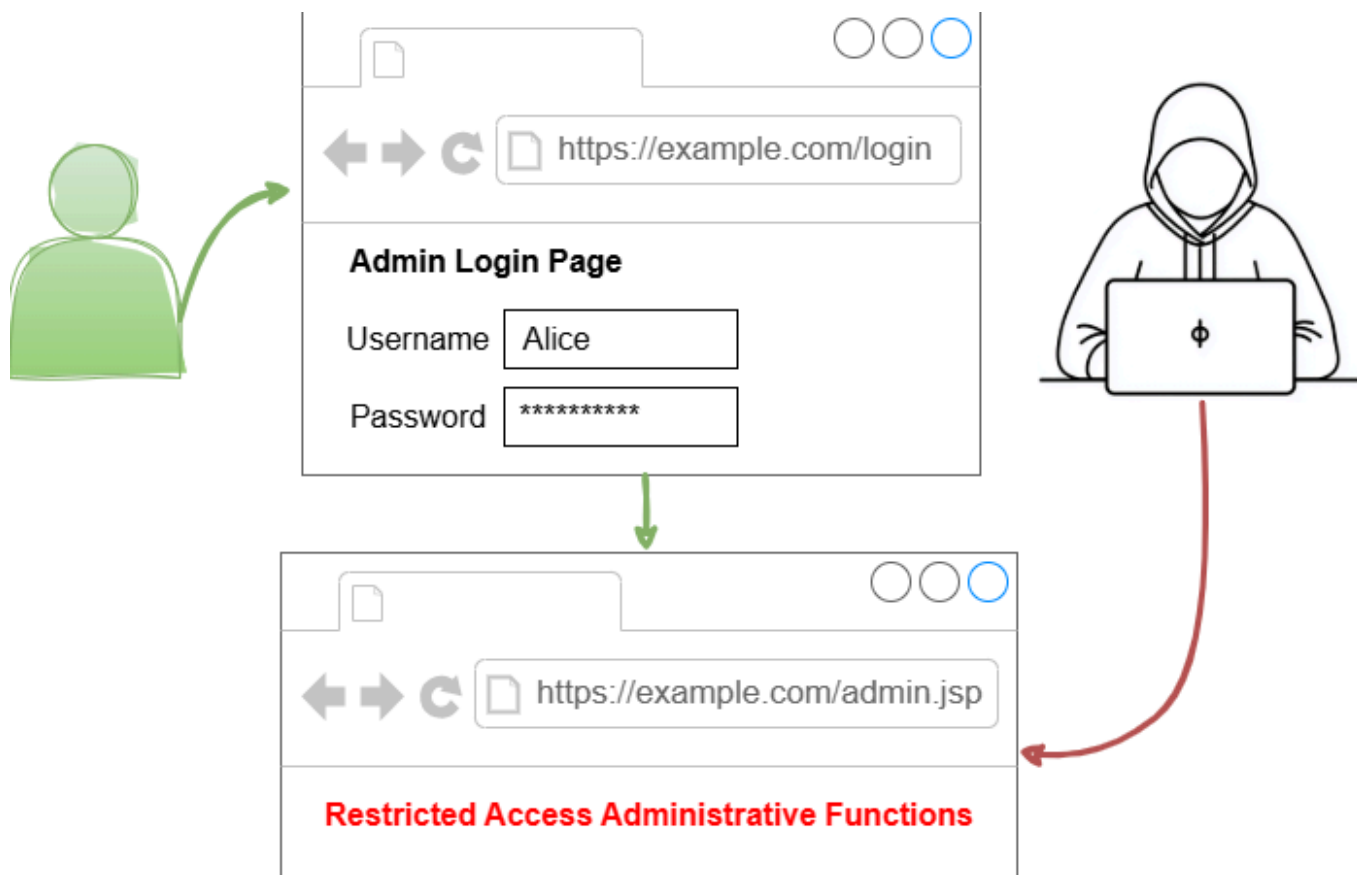


Forced Browsing Vulnerability Report

Summary

In a recent engagement on a vulnerability disclosure program, I identified a **direct request (Predictable resource location)** vulnerability within a subdomain and I managed to replicate the same issue on a second subdomain. This occurs when the web application fails to enforce proper **authorization controls** at the server level. As a result, unauthenticated or low-privilege users can access sensitive resources simply by guessing or brute-forcing the URL path and bypassing the intended authentication process.



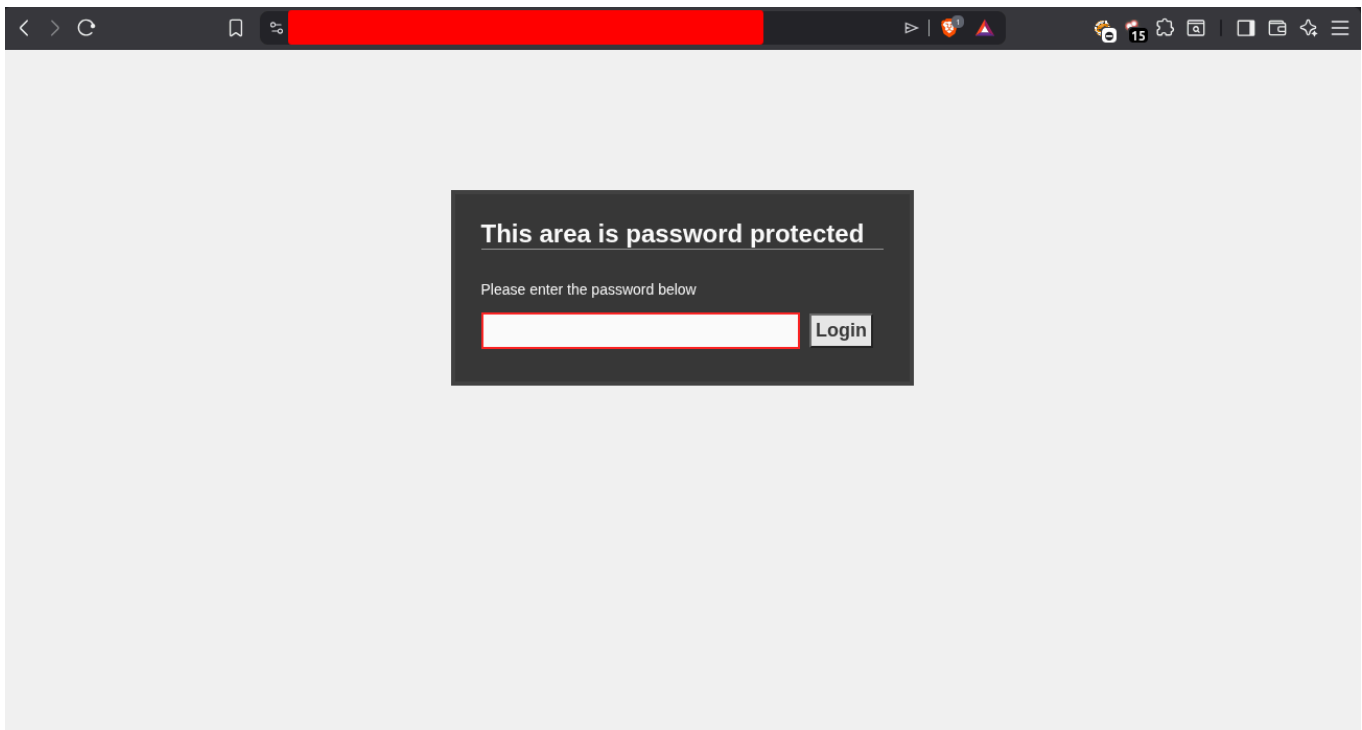
In this specific case, extensive enumeration, OSINT, and pattern recognition were needed to discover this issue. The vulnerability was responsibly submitted to the organization in order to be fixed, the security and business impact was unauthenticated access to internal assets which was demonstrated with a proof of concept highlighting:

- Details of internal facility layouts that can highly assist physical attacks.
- PII disclosure of full names, roles, phone numbers and emails, including key stakeholders which enables social engineering attacks like spear-phishing.
- Sensitive financial information of the organization and future plans for third parties that were designed for internal use, which affects customer trust and legal non-compliance penalties.

Reconnaissance

After examining the scope details, testing policy and the organization's business, my information gathering process for this black-box assessment started with subdomain enumeration through various tools such as **subfinder**, **Assetfinder**, **Amass**, and sources like censys, shodan, etc. I also identified the tech stack and infrastructure used for the web applications, which primarily consisted of assets like Apache, PHP, Microsoft IIS, and WordPress.

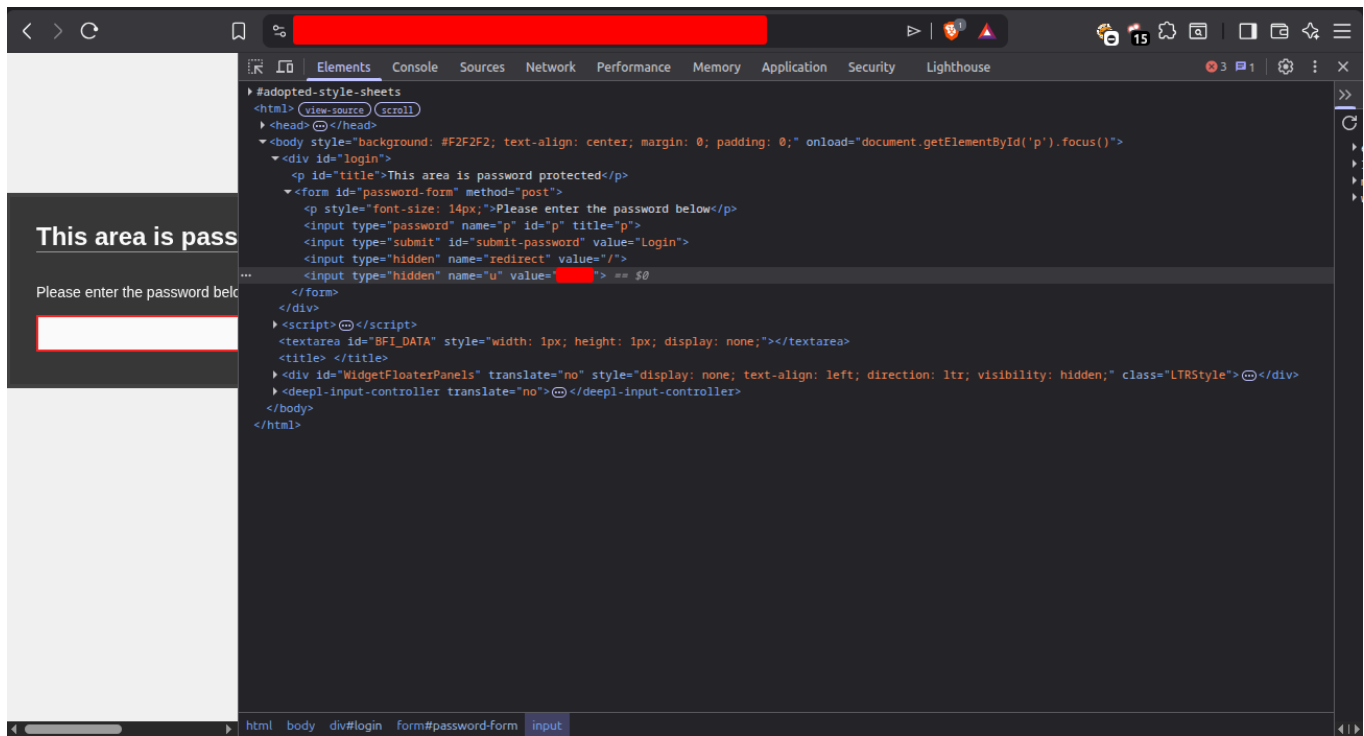
Considering the massive scope, I proceeded to choose a few points of interest for manual testing, while keeping my automated tools running in the background on other targets. One of the interesting areas was the following subdomain that had a unique login panel.



The first thing that caught my attention was that only a password was required as input, no username, no email or any sort of Identification. It seemed unusual, especially since the subdomain name indicated it was used for internal, private purposes.

After inspecting the source code it appeared that the stack used was Weebly, a cloud-based website builder and web hosting service that is mostly used because of its ease of use.

In addition, I identified a hard-coded username that seems to be set by default. While this explained why the panel only required a password, it was concerning from a security perspective, requiring a password only would simplify and increase the chances of a brute force attack.



A few attempts of guessing the password with default and common ones didn't achieve access as expected, but always worth a try. Directory enumeration didn't result in any discovery, and reporting this as lack of rate limiting was not an attractive choice. So I decided to dig deeper.

Breakthrough

Additional effort with OSINT assistance resulted in discovering two massive clues and led to identifying the vulnerability, which is explained in the following two sections:

1. Web archives:

The Wayback Machine is a digital archive of the World Wide Web, a useful resource that allows anyone to view archived snapshots of websites and documents from the past that might have been deleted, restricted or updated to not be available in the present. With the help of this service, I managed to identify a URL path of a deleted document.

INTERNET ARCHIVE

WEBTEXTSVideosAUDIOSoftware

AllSearch

SIGN UP | LOG IN | UPLOAD

ABOUTBLOGEVENTSPROJECTSHELPDONATECONTACTJOBSVOLUNTEER

DONATE

INTERNET ARCHIVEWayBackMachine

Explore more than 1 trillion web pages saved over time

Calendar · Collections · Changes · Summary · Site Map · URLs

2 URLs have been captured for this URL prefix.

Filter results by URL or MIME Type (i.e. ".txt")

URL	MIME Type	From	To	Captures	Duplicates	Uniques
	text/html	Dec 21, 2024	Mar 2, 2025	7	5	2
	warc/revisit	Dec 21, 2024	Dec 21, 2024	1	0	1

Showing 1 to 2 of 2 entries

FirstPrevious1NextLast

FAQ | Contact Us | Terms of Service (Dec 31, 2014)

The path started with an upload directory which is very common for most web apps, but beyond that it was a set of strange digits and a number, the number was basically the digits combined so an example would be the following:

```
/uploads/digit/digit/digit/digit/number/document-name
```

Considering the size of the organization, this appeared to be a technique to prevent too many files and folders from accumulating in a single directory, it provided insights for me on how the files are organized.

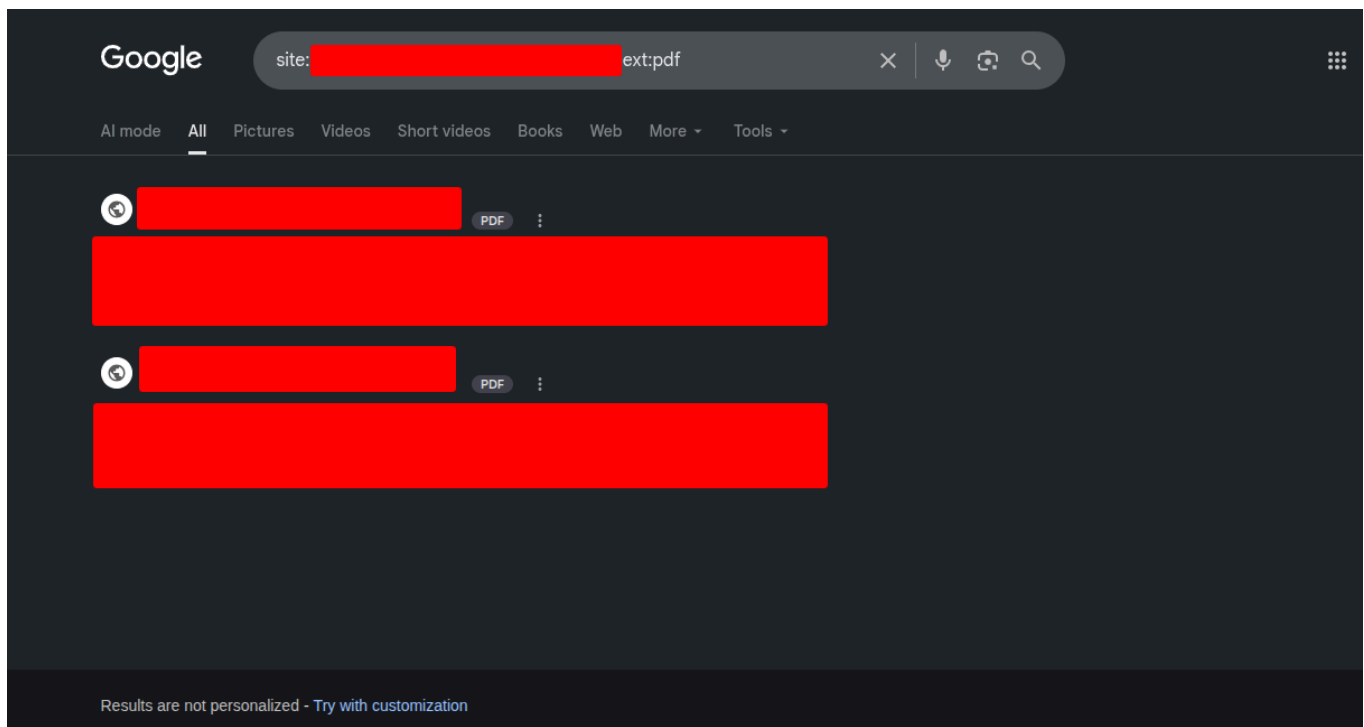
After attempting to access the same number directory, it resulted in a 404 response meaning that it was not found. This indicated that the entire directory was potentially deleted.

2. Google dorking

Google Dorking, also known as Google Hacking which is the practice of using advanced search operators to uncover sensitive, hidden, or mistakenly indexed data on the internet.

While this seemed to be another procedure for me to go through, it was actually the piece of the puzzle i needed the most. After attempting some advanced google searching filters, the following google dork is what provided only two results that were the second discovery:

```
Site:Subdomain ext:pdf
```



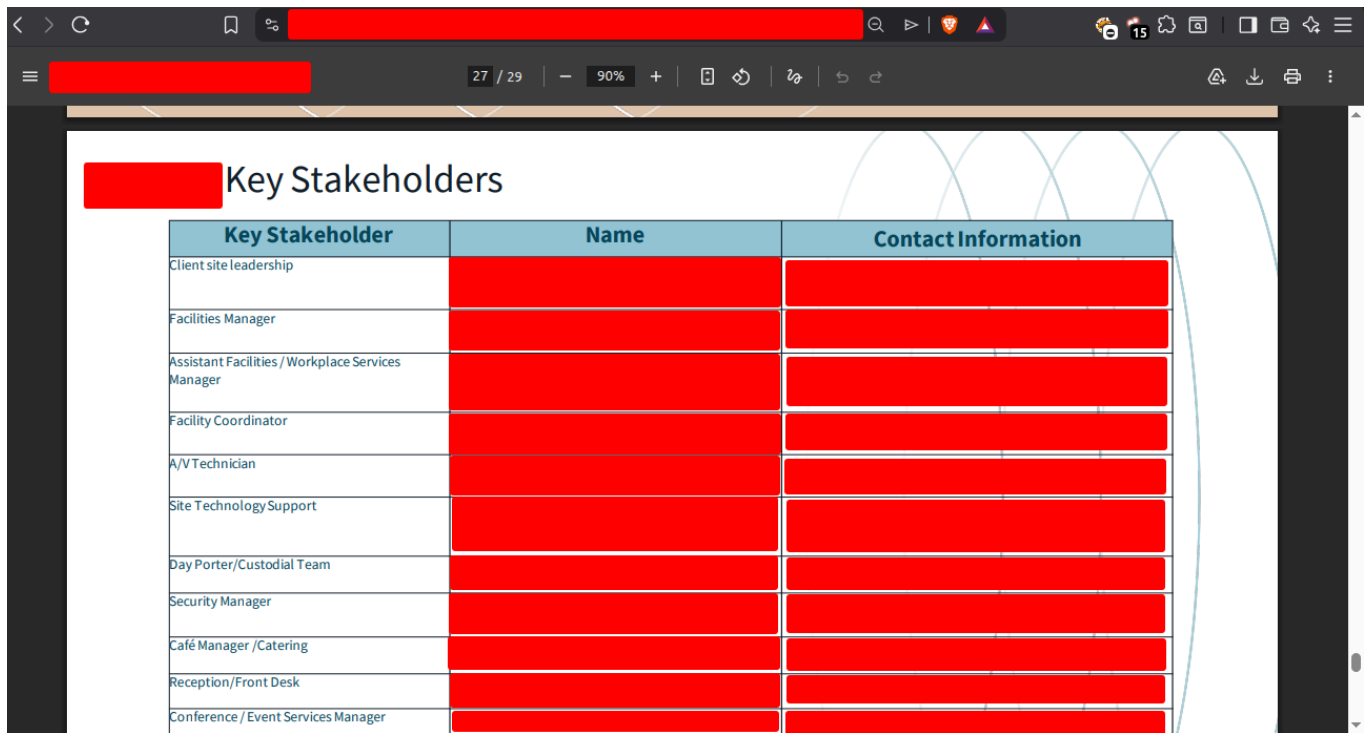
The two documents were highly sensitive on their own, but being able to access them did raise question marks. If the subdomain root requires a password then how did I manage to view those two assets? The first option would be that they were configured to be publicly available which would mean that it's not a real issue, the second option was that it's a forced browsing vulnerability, and it was the case later on although it wasn't simple to prove since I had to find the exact URL of anything sensitive to prove impact, the discoveries provided me a huge assist.

Proof of Concept

The path for the two documents had a similar structure to the deleted path mentioned earlier, but with higher value numbers, which is logical since more directories are needed to store the files, that is :

```
/uploads/digit/digit/digit/digit/number/document-name
```

After many attempts of manipulating this path while relying on the business logic of the recent findings. Specifically trying lower value digits as well as the number, a methodology similar to IDOR discovery. I finally managed to access a directory that had an internal document with a lot of sensitive information such as PII disclosure for critical roles.

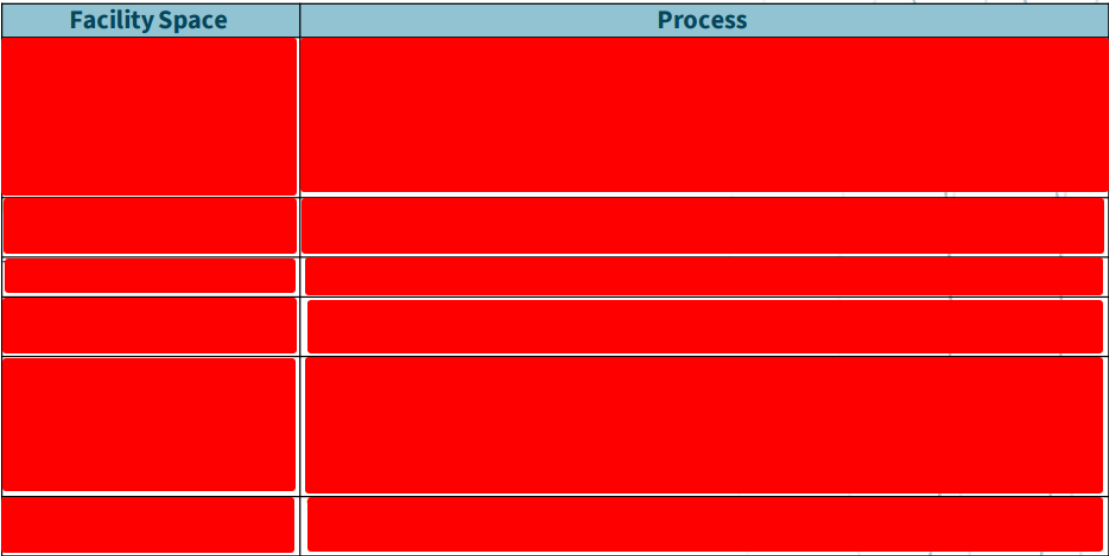


The screenshot shows a PDF document titled "Key Stakeholders" with a table containing contact information for various roles. The table has three columns: "Key Stakeholder", "Name", and "Contact Information". The content is redacted with black boxes.

Key Stakeholder	Name	Contact Information
Client site leadership		
Facilities Manager		
Assistant Facilities / Workplace Services Manager		
Facility Coordinator		
A/V Technician		
Site Technology Support		
Day Porter/Custodial Team		
Security Manager		
Café Manager /Catering		
Reception/Front Desk		
Conference / Event Services Manager		

Details regarding facility layouts, internal financial information, and future organizational plans were also present in the document.

Site Information



Facility Space	Process

While discovering this type of uncommon vulnerability took a good amount of time and effort, I was glad to improve the security of the organization, gain more experience and level up my research skills once again. It was later confirmed by the security team that the misconfiguration exists at the **infrastructure level** of the third party vendor, which took longer to fix.

Thank you, the app team is reaching out to Weebly (vendor) to get this sorted out.

Regards,

Conclusion

Based on the CVSS v4.0 metrics (AV:N/AC:L/PR:N/UI:N/VC:H/VI:N/VA:N), this vulnerability aligns with a **High (Base Score ~7.5+)** classification. The combination of PII exposure, unauthenticated access (PR:N) to highly sensitive physical security and facility layout documentation presents a critical risk to the client's physical operations.

Extensive reconnaissance, piecing anomalies together, recognizing what to inspect, and staying more persistent than most people can make all the difference in cyber security research. More information about this vulnerability can be found in the following link:

[Forced Browsing](#)